

findings.md

OWASP Juice Shop - Findings Notes

1. Authentication Request Analysis

Endpoint: /rest/user/login

Observation: Captured login requests containing plaintext credentials inside HTTP request bodies.

Example:

```
{ "email": "admin@juice-sh.op", "password": "admin123" }
```

Risk: Sensitive credential exposure during authentication traffic analysis.

OWASP: A02 – Cryptographic Failures

2. JWT Token Disclosure

Endpoint: /rest/user/login

Observation: JWT authentication token exposed in login response.

Exposed Claims:

- email
- role
- internal user ID
- password hash

Risk: Sensitive information disclosure through JWT payload.

OWASP: A02 – Cryptographic Failures

3. Password Hash Exposure

Observation: Password hash visible inside decoded JWT payload.

Risk: Potential offline password cracking attempts.

Severity: High

4. User Enumeration Testing

Endpoint: /api/Users

Observation: User-related information accessible through API responses.

Risk: Attackers may identify valid user accounts and administrative users.

OWASP: A01 – Broken Access Control

5. IDOR Testing

Endpoint: /api/BasketItems/

Observation: Modified BasketId values during authenticated request testing.

Example:

BasketId: 1 → 2

Objective: To test authorization validation for object references.

OWASP: A01 – Broken Access Control

6. JWT Signature Validation

Observation: Modified JWT tokens were rejected by the application.

Result: JWT signature verification protections appeared properly enforced.

Security Impact: Reduced risk of JWT forgery.

7. Security Header Assessment

Observed Headers:

- X-Frame-Options
- X-Content-Type-Options

Missing Headers:

- Content-Security-Policy
- Strict-Transport-Security
- X-XSS-Protection

Risk: Incomplete HTTP security hardening.

OWASP: A05 – Security Misconfiguration

8. Tools Used

- Burp Suite Community Edition
 - OWASP Juice Shop
 - JWT.io
 - Kali Linux
 - Chromium Browser
-

9. Skills Demonstrated

- HTTP Traffic Analysis
- Burp Repeater Testing
- JWT Security Analysis
- API Security Testing
- Access Control Assessment
- OWASP Top 10 Mapping
- Security Header Analysis